

Network Security Assessment

Target: sample_vulnerable_scan.xml

Scanned: 2026-08-04T11:36:02

Nmap invocation: `nmap -sT -sV -p- -oX sample\_vulnerable\_scan.xml 192.168.56.101`

Hosts up: 1

Rule-engine findings: critical: 6 · high: 7 · medium: 2

Analyst: llama-3.3-70b-versatile (Groq)

Prepared by: Faozan Mujtaba — Zynxis Agentic AI Internship, Week 6

This assessment covers an authorised scan only. Version-based findings are inferred from service banners and require verification against vendor advisories before being treated as confirmed vulnerabilities.

Executive Summary

The scanned host, metasploitable.local, exposes 22 open ports, indicating a high level of exposure to potential attacks. The most urgent issue is the presence of a backdoored vsftpd 2.3.4 on port 21, which poses a significant risk to the host's security. The large number of open ports and services suggests that this host may be intentionally configured as a public-facing server, but the presence of critical vulnerabilities and outdated software raises concerns about its overall security posture.

Risk Assessment by Host

The metasploitable.local host has a poor overall posture due to the large number of open ports and services, many of which are outdated or vulnerable to attacks. The following table summarizes the key findings:

Severity	Finding	Port	Why it matters
CRITICAL	Outdated software: vsftpd 2.3.4	21	Backdoored version of vsftpd
CRITICAL	Cleartext service exposed	23	Telnet transmits credentials and session data in cleartext
CRITICAL	Cleartext service exposed	513	rlogin is an unauthenticated legacy remote-access protocol
CRITICAL	Cleartext service exposed	514	rsh trusts the client's word for identity
CRITICAL	Database service reachable	3306	MySQL is listening on a network-reachable port
CRITICAL	Database service reachable	5432	PostgreSQL is listening on a network-reachable port
HIGH	Cleartext service exposed	21	FTP transmits credentials and data in cleartext
HIGH	Outdated software: OpenSSH 4.7p1	22	OpenSSH build predates 7.4; several user-enumeration and key-handling issues apply
HIGH	Cleartext service exposed	25	SMTP without enforced STARTTLS can expose mail in transit
HIGH	Outdated software: Apache httpd 2.2.8	80	Apache httpd 2.2 reached end of life in 2018 and receives no security fixes
HIGH	Remote administration surface: SMB	445	SMB grants broad control of the host and is a primary target for credential-stuffing and known-exploit attacks
HIGH	Outdated software: ProFTPD 1.3.1	2121	ProFTPD 1.3.0-1.3.3 covers several remote-code-execution advisories

Severity	Finding	Port	Why it matters
HIGH	Remote administration surface: VNC	5900	VNC grants broad control of the host and is a primary target for credential-stuffing and known-exploit attacks
MEDIUM	Large attack surface	-	22 open ports increase the host's vulnerability to attacks
MEDIUM	HTTP served without HTTPS	80	Traffic to this host has no TLS option, so sessions and credentials travel in the clear

Suspicious Indicators

The presence of a backdoored vsftpd 2.3.4 on port 21 and the exposure of cleartext services on ports 23, 513, and 514 suggest potential misconfiguration or compromise. The large number of open ports and services, including some that are outdated or vulnerable, raises concerns about the host's overall security posture.

Likely Vulnerabilities

The following vulnerability classes are implied by the detected software and versions:

- Remote code execution (REQUIRES VERIFICATION): vsftpd 2.3.4, ProFTPD 1.3.1
- Authentication bypass (REQUIRES VERIFICATION): OpenSSH 4.7p1, Samba smbd 3.X - 4.X
- Data exposure (CONFIRMED): cleartext services on ports 21, 23, 25, 513, and 514
- Denial of service (REQUIRES VERIFICATION): Apache httpd 2.2.8, PostgreSQL DB 8.3.0 - 8.3.7

Prioritised Remediation

1. **Update vsftpd to a secure version** (metasploitable.local, port 21, medium effort): Replace the backdoored vsftpd 2.3.4 with a secure version to prevent remote code execution attacks. 2. **Disable cleartext services** (metasploitable.local, ports 23, 513, and 514, low effort): Disable telnet, rlogin, and rsh services to prevent cleartext transmission of credentials and session data. 3. **Configure MySQL and PostgreSQL to listen on a private network or firewall** (metasploitable.local, ports 3306 and 5432, medium effort): Restrict access to database services to prevent unauthorized access. 4. **Update OpenSSH to a secure version** (metasploitable.local, port 22, medium effort): Replace OpenSSH 4.7p1 with a secure version to prevent user-enumeration and key-handling issues. 5. **Enable STARTTLS for SMTP** (metasploitable.local, port 25, low effort): Configure Postfix smtpd to enforce STARTTLS to prevent exposure of mail in transit. 6. **Update Apache httpd to a secure version** (metasploitable.local, port 80, medium effort): Replace Apache httpd 2.2.8 with a secure version to prevent known vulnerabilities. 7. **Restrict access to SMB and VNC services** (metasploitable.local, ports 445 and 5900, medium effort): Configure Samba smbd and VNC to restrict access to authorized users and prevent credential-stuffing and known-exploit attacks. 8. **Update ProFTPD to a secure version** (metasploitable.local, port 2121, medium effort): Replace ProFTPD 1.3.1 with a secure version to prevent remote-code-execution attacks. 9. **Disable unnecessary services** (metasploitable.local, various ports, low effort): Disable any unnecessary services to reduce the host's attack surface. 10. **Enable HTTPS for HTTP services** (metasploitable.local, port 80, medium effort): Configure Apache httpd to serve HTTPS to prevent exposure of sessions and credentials.